

Juridisch Adviesrapport: Aansprakelijkheid en Compliance voor AI-SaaS in de Kappers- en Gezondheidszorgsector

Datum: 24 mei 2024 **Onderwerp:** Strategische analyse van aansprakelijkheidsrisico's en wettelijke kaders voor SaaS-aanbieders en resellers bij de implementatie van AI-architecturen.

1. Strategisch Kader: De Convergentie van AVG en de AI Act

De transitie van vrijblijvende AI-experimenten naar een strikt gereguleerd landschap bereikt in de periode 2024-2026 een kritieke fase. Voor SaaS-ontwikkelaars en hun distributeurs is compliance niet langer een juridisch bijproduct, maar het fundament van marktconformiteit en reputatiemanagement. Een enkel datalek of een niet-conforme AI-implementatie kan leiden tot onherstelbare reputatieschade en boetes die oplopen tot €35 miljoen of 7% van de wereldwijde jaaromzet. In dit nieuwe ecosysteem verschuift de juridische kwalificatie van rollen ingrijpend:

- **Aanbieder (Provider):** De SaaS-developer die een AI-systeem ontwikkelt of bestaande foundation-modellen (zoals GPT-4 of Claude via API) integreert in een eigen product. Juridisch wordt de developer die LLM's inzet voor specifieke sectoren gezien als de 'aanbieder' van een *downstream* AI-systeem, wat de volledige productaansprakelijkheid onder de AI Act met zich meebrengt.
- **Gebruiksverantwoordelijke (Deployer):** De kapsalon of zorgverlener die het AI-systeem inzet. Zij dragen de verantwoordelijkheid voor het feitelijk gebruik en de directe interactie met betrokkenen.
- **Distributeur (Reseller):** De partij die het systeem op de markt aanbiedt. Zij moeten verifiëren of de aanbieder aan alle conformiteitseisen voldoet. De convergentie van de AVG en de AI Act betekent dat de technische architectuur (Privacy by Design) de enige effectieve methode is om strategische risico's te mitigeren.

2. Classificatie van Persoonsgegevens: De Impact van Artikel 9 AVG

Een correcte datakwalificatie is het fundament voor de juridische grondslag. In de kappers- en gezondheidszorgsector is de grens tussen cosmetische data en medische informatie flinterdun. Zodra een systeem fysieke kenmerken of condities vastlegt ter voorkoming van schade of voor advies, verschuift het regime onvermijdelijk naar 'bijzondere persoonsgegevens'. Gegevens over hoofdhuidcondities (alopecia, psoriasis), allergieën voor kleurstoffen en de resultaten van patch-tests zijn onherroepelijk gezondheidsgegevens (Artikel 9 AVG). Ook 'voor-en-na-foto's' moeten in deze context als bijzonder worden geclassificeerd; zij bevatten biometrische kenmerken en onthullen vaak de fysieke of etnische status van de klant. Voor deze gegevens is de grondslag 'gerechtvaardigd belang' uitgesloten; er is altijd **expliciete, gedocumenteerde en afzonderlijke toestemming** vereist.

Gegevenstype	AVG-Classificatie	Juridische Grondslag	Beveiligingsregime
-----	-----	-----	Naam, Tel, E-mail Gewoon persoonsgegeven Uitvoering overeenkomst (Art. 6.1.b) TLS 1.2+ / AES-256 Allergieën / Patch-tests Bijzonder (Gezondheid) Expliciete toestemming (Art. 9.2.a) AES-256 + MFA + PII-masking Hoofdhuidcondities (Alopecia) Bijzonder (Gezondheid) Expliciete toestemming (Art. 9.2.a) AES-256 + MFA + PII-masking Voor-en-na-foto's Bijzonder (Biometrisch/Gezondheid) Expliciete toestemming (Art. 9.2.a) Geïsoleerde opslag + Directe intrekbaarheid

3. AI Voice Agents en Biometrische Risico's

De inzet van AI Voice Agents voor telefonische boekingen introduceert unieke risico's. Spraak is een ongestructureerd, biologisch rijk medium waarbij de verwerking direct biometrische bepalingen activeert.

- **Stembiometrie en Diarization:** Het omzetten van vocale kenmerken naar een 'stemafdruk' (voiceprint) valt onder Artikel 9 AVG. Het gebruik van 'diarization' (sprekerherkenning) zonder voorafgaande kennisgeving is juridisch ontoelaatbaar.
- **Ambient Capture:** Voice agents registreren vaak onbedoeld stemmen van omstanders (bystanders). Dit creëert onvrijwillige datacollectie waarvoor geen rechtsgrond bestaat.
- **Wettelijke Deadlines Emotie-AI:**
- **Februari 2025 (Verbod):** Het gebruik van AI voor emotieherkenning op de werkplek (bijv. het monitoren van de stemming van salonmedewerkers) is vanaf heden **absoluut verboden** onder Artikel 5(1)(f) van de AI Act.
- **Augustus 2026 (Hoog Risico):** Emotieherkenning bij klanten (bijv. analyse van frustratie via stemtoon) wordt geclassificeerd als **hoog risico**. Dit vereist verplichte conformiteitsbeoordelingen, menselijk toezicht en een expliciete waarschuwing vóórdat de analyse start.

4. Platformcompliance: WhatsApp Business API vs. App

Voor professionele SaaS-toepassingen binnen de EER is de keuze voor de juiste infrastructuur dwingend. De *WhatsApp Business App* (de gratis versie) is niet-compliant vanwege de verplichte upload van de volledige contactenlijst naar Meta, inclusief nummers van derden zonder toestemming. De **WhatsApp Business API** is het enige toegestane kanaal. Hierbij verlopen gegevens via beveiligde endpoints en is hosting binnen de EER mogelijk. **Regulated Verticals & Telemedicine:** Meta verbiedt in haar Business Messaging Policy het uitwisselen van gezondheidsinformatie indien de lokale wetgeving (zoals de AVG) "verhoogde eisen" (heightened requirements) stelt waaraan het platform niet kan voldoen. Aangezien gezondheidsdata in de EU onder het verzwaarde regime van Artikel 9 valt, is het gebruik van WhatsApp voor medische consultatie of het uitwisselen van medische dossiers een direct compliancerisico. Bovendien mogen healthcare-producten nooit via in-chat commerce (Catalogs) worden verkocht.

5. Architecturale Best Practices en Data Governance

Juridische claims moeten technisch onmogelijk worden gemaakt door 'Privacy by Design'.

- **Intelligent Tokenization:** SaaS-developers dienen de **Protecto-methode** te implementeren. Hierbij worden Personally Identifiable Information (PII) gedetecteerd en vervangen door tokens voordat de data naar een extern LLM (zoals OpenAI) wordt verzonden. De mapping-tabel wordt buiten het bereik van de AI opgeslagen.
- **RAG-beveiliging (Retrieval-Augmented Generation):** Systemen die gebruikmaken van vector-databases zijn kwetsbaar voor **Prompt-Injection** en **Jailbreaking**. Kwaadwillende gebruikers kunnen de AI manipuleren om gevoelige data van andere klanten uit de database te extraheren. Beveiliging moet zich richten op het voorkomen van kwaadaardige extractie van de gehele database.
- **Watermarking (Art. 50(2) AI Act):** Alle door AI gegenereerde synthetische content (tekst of spraak) moet worden voorzien van een onzichtbare, robuuste en

machineleesbare markering (watermerk) om de AI-herkomst traceerbaar te maken.

- **Recht op Vergetelheid in Vector-DB's:** Omdat embeddings semantische sporen bevatten, is het wissen van bronbestanden onvoldoende. Elke embedding moet worden voorzien van metadata-tags (klant-ID) om bij een verwijderverzoek (Art. 17 AVG) alle sporen in chatlogs en vector-clusters te kunnen purgen.

6. Contractuele Verdeling van Aansprakelijkheid

In de keten van developer tot eindgebruiker is contractuele vrijwaring essentieel om marktstagnatie te voorkomen. De SaaS-Resellerovereenkomst moet de volgende clausules bevatten:

1. **Garantie van Toestemming:** De volledige verantwoordelijkheid voor het verkrijgen van expliciete opt-ins voor Artikel 9-gegevens ligt bij de salon/zorgverlener. De developer wordt gevrijwaard van boetes door het ontbreken hiervan.
2. **90-dagen Tail Period:** Bij contractbeëindiging geldt een termijn voor veilige datamigratie, gevolgd door een gecertificeerde vernietiging van alle kopieën bij de developer en reseller.
3. **Revenue Commits:** Exclusiviteitsrechten voor resellers moeten gekoppeld zijn aan ARR-doelstellingen om te voorkomen dat een onderpresterende partner een marktsegment blokkeert.

7. Compliance Roadmap 2024-2026

Een proactieve houding ten opzichte van toezichthouders is cruciaal. Het onderstaande tijdspad is dwingend voor het behoud van markttoegang: | Fase | Deadline | Actie || ----- | ----- || **1. Eliminatie** | Direct | Ban de WhatsApp Business App en consumenten-AI (gratis ChatGPT) uit alle werkprocessen. || **2. Sanering** | Q4 2024 | Implementeer PII-redactie en watermarking (Art. 50(2)) in alle AI-pijplijnen. || **3. Verbod** | Feb 2025 | Staak elke vorm van AI-emotieherkenning bij werknemers conform de AI Act. || **4. Validatie** | Q4 2025 | Voer een DPIA en conformiteitsbeoordeling uit voor alle RAG- en Voice-systemen. || **5. Handhaving** | Aug 2026 | Volledige audit op hoogrisico-systemen (klant-emotieanalyse) en biometrische logging. |

Compliance is geen administratieve last, maar het operationele fundament voor marktsucces en de bescherming van uw meest waardevolle asset: het consumentenvertrouwen.